



ANIMAL HEALTH INSTITUTE
ICT POLICY & PROCEDURES.

Table of Contents

Lists of tables	6
Lists of Abrevation	7
Terms of Defination	8
1 Objectives	1
2. Scope	1
3. Enforcement & Review	1
4. Policy and Procedures control descriptions.....	1
4.1 Asset Management	3
Over View	3
Name: ICT Asset Management Policy	4
4.1.1. Purpose.....	4
4.1.2. Asset Identification & Inventory.....	4
4.1.3. Ownership of Assets	4
4.1.4. Acceptable Use of Assets	4
4.1.5. Classification of Information	5
4.1.6. Labeling of Information	5
4.1.7. Return and Disposal of Assets	5
4.2. Access Control Policy.....	6
Over View	6
Name: ICT Access Control Policy	6
4.2.1. Purpose.....	7
4.2.2. General Principles.....	7
4.2.3. User Access Management	7
4.2.4. Authentication Requirements	7
4.2.5. Privileged Access Management.....	8
4.2.6. Remote Access & Mobile Devices	8
4.2.7. Monitoring & Logging	8
4.3. Information Security Policy	9
Overview.....	9

Name: Information Security Policy	10
4.3.1. Purpose.....	10
4.3.2. Objectives.....	10
4.3.4. Management Responsibilities	10
4.3.5. Key Security Principles.....	10
4.4. Communication Security Policy	12
Overview.....	12
Name: ICT Communication Security Policy.....	13
4.4.1. Purpose.....	13
4.4.2. Network Controls.....	13
4.4.3. Security of Network Services	13
4.4.4. Information Transfer	13
4.4.5. Web Filtering & Electronic Messaging.....	14
4.4.6. Social Media & work time and device	14
4.4.7. Network Redundancy.....	14
4.5. Compliance Security Policy	15
Over View	15
Name: ICT Compliance Security & Legal Policy	16
4.5.1. Purpose.....	16
4.5.2. Identification of Legislation	16
4.5.3. Intellectual Property Rights (IPR).....	16
4.5.4. Protection of Records	16
4.5.5. Privacy and Protection of PII.....	17
4.5.6. Regulation of Cryptographic Controls	17
4.5.7. Independent Review of Information Security.....	17
4.6. Cryptography & Encryption Policy	18
Over View	18
Name: ICT Cryptography & Encryption Policy.....	19
4.6.1. Purpose.....	19
4.6.2. General Principles.....	19
4.6.3. Data at Rest.....	19
4.6.4. Data in Transit	20

4.6.5. Key Management	20
4.6.6. Digital Signatures.....	20
4.7. Human Resource Security	21
Overview.....	21
Name: ICT Human Resource Security Policy.....	22
4.7.1. Purpose.....	22
4.7.2. Prior to Employment.....	22
4.7.3. During Employment.....	22
4.7.4. Termination or Change of Employment.....	22
4.7.5. Remote Working & Bring Your Own Device (BYOD)	23
4.8. Business Continuity & Resilience Policy.....	24
Overview.....	24
Name: ICT Business Continuity & Resilience Policy	24
4.8.1. Purpose.....	25
4.8.2. Planning for Information Security Continuity	25
4.8.3. ICT Readiness.....	25
4.8.4. Backup and Redundancy	26
4.8.5. Response and Recovery Procedures.....	26
4.8.6. Testing and Review.....	26
4.9. Policies for Information Security.....	27
Overview.....	27
Name: Policy for Information Security Policies.....	27
4.10.1. Purpose	28
4.10.2. Policy Hierarchy	28
4.10.3. Creation and Format.....	28
4.10.4. Review and Approval.....	28
4.10.5. Communication.....	29
4.10.6. Exceptions	29
4.10. Operations Security Policy	30
Overview.....	30
Name: ICT Operations Security Policy	30
4.10.1. Purpose	31

4.10.2. Operating Procedures	31
4.10.3. Change Management.....	31
4.10.4. Capacity Management.....	31
4.10.5. Malware Protection	32
4.10.6. Logging and Monitoring.....	32
4.10.7. Technical Vulnerability Management	32
4.10.8. Information Security Roles & Responsibilities.....	32
4.10.9. Segregation of Duties	32
4.10.10. Information Security in Project Management	33
4.11. Physical and Environmental Security	34
Overview.....	34
Name: Physical and Environmental Security Policy	34
4.11.1. Purpose	35
4.11.2. Physical Security Perimeters	35
4.11.3. Physical Entry Controls.....	35
4.11.3. Securing Offices, Rooms, and Facilities.....	35
4.11.5. Physical Security Monitoring	35
4.11.6. Protecting Against Physical and Environmental Threats.....	35
4.11.7. Working in Secure Areas.....	36
4.11.8. Equipment Siting and Protection	36
4.11.9. Secure Disposal or Reuse of Equipment	36
4.12. Supplier Relationships Security.....	37
Overview.....	37
Name: Supplier Relationships Policy	37
4.12.1. Purpose	38
4.12.2. Information Security in Supplier Relationships	38
4.12.3. Addressing Security within Supplier Agreements	38
4.12.4. Managing Information Security in the ICT Supply Chain.....	38
4.12.5. Monitoring and Review of Supplier Services	38
4.12.6. Managing Changes to Supplier Services	39
4.13. System acquisition, development, & maintenance Security.....	40
Overview.....	40

Name: System Acquisition, Development, and Maintenance Policy..... 40

4.13.1. Purpose 41

4.13.2. Secure Requirements & Acquisition 41

4.13.3. Secure Development Lifecycle 41

4.13.4 Protection of Test Data..... 41

4.13.5. System Acceptance Testing 41

4.13.6. Secure System Engineering 42

4.13.7. Maintenance and Change Management..... 42

APPENDIX I: User AcknowledgmentI

Lists of tables

Table 1 Policy and Procedures controls descriptions 1

Table 0-1: Classification of Information.....**Error! Bookmark not defined.**

Table 0-1 recovery time schedules.....**Error! Bookmark not defined.**

Lists of Abrevation

ADSL	Asymmetric Digital Subscriber Line
ADDS	Active Directory Domain Services
AHI	Animal Health Institute
AUP	Acceptable Use Policy
AWS KMS	AWS Key Management Service
CCTV	Closed-Circuit Television
DHCP	Dynamic Host Protocol System
DNS	Domain Name System
DLCI	Data link connection identifier
ERP	Enterprise Resource Planning Software
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
ISDN	Integrated service digital network
ICT	Information Communication Technology.
IDPS	Intrusion Detection and Prevention System
ISMS	Information Security Management System
ISO/IEC	International Standard of Organization/ International Electrotechnical Commission
INSA	Information Network Security Agency
IP	Internet protocol
IZSAM	Istituto Zooprofilattico Sperimentale of Abruzzo and Molise
MFA	Multi Factor Authentication
NOC/SOC	Network Operation Center/ Security Operation Center
PSA	Private Security Authority
SDLC	Software Development Life Cycle
SILABFA	Sistema Informativo Labratore short for LIMS for Africa.
S/MIME	Secure/Multipurpose Internet Mail Extensions
TLS	Transport Layer Security
VLAN	Virtual Local Area Network
VPN	Virtual Private Network
WPA	Wi-Fi Protected Access

Terms of Defination

The Information Asset Register (IAR): Usually a spreadsheet or an automated tool output like Jamf, Intune, or Snipe-IT.

Disposal Certificates: Proof from a third-party vendor that old hard drives were shredded.

Onboarding/Offboarding Checklists: A document showing a staff member signed for their laptop and another showing they returned it. Or an Evidence showing that a recently departed employee's account was disabled on their last day.

Software License Review: Evidence that are tracking and managing software assets/licenses to prevent "Shadow IT."

User Access List: A current list of users including their assigned roles.

Evidence of Review: Minutes or a signed spreadsheet from last quarterly "Access Review."

Legal & Regulatory Register: A list of laws (like GDPR, Cyber Security Acts) that apply to critical infrastructure

Data Retention Policy: A document stating how long AHI keep logs, emails, and customer data after employee's retirement or termination.

Privacy Policy (Internal and External): Evidence of how the institutes handle PII.

Internal Audit Reports: Documented proof that AHI checked individuals own compliance in the last 12 months.

Network Diagram: A visual map showing how the network is segregated (VLANs, Firewalls, DMZs).

Firewall Ruleset Review: Evidence that the institute ICT committee review the firewall rules periodically (e.g., every 6 months) to remove old or "any-any" rules.

SSL/TLS Certificates: Evidence that AHI's web-facing services are using valid, up-to-date certificates (no expired or SHA-1 certs).

Encryption Standards Document: A technical sheet listing the institutes approved algorithms (AES-256, TLS 1.3, etc.).

MDM Report: A report showing that 100% of company laptops have "Encryption Active."

Key Management Audit Log: Evidence showing who has accessed the Key Vault and when keys were last rotated.

SSL Labs Report: A third-party scan (like SSL Labs.com) of your website showing an "A" rating for TLS configuration.

Signed NDAs: A sample of employment contracts showing signed confidentiality clauses.

Training Logs: A report from the institute's human resource or a simple spreadsheet showing 100% training completion.

Screening Records: Evidence that background checks were performed for high-privilege roles.

Offboarding Proof: A "Termination Checklist" signed by both HR and ICT, proving that a specific former employee's access was cut on their last day.

Disaster Recovery Plan (DRP): The actual manual of the institute's ICT team would use if the server room had a critical natural disaster.

Backup Logs & Test Results: Evidence of successful daily backups and a log showing the last time you successfully *restored* a file.

Tabletop Exercise Minutes: Notes from a meeting where management walked through a "What if we get hit by Ransomware?" scenario.

Illegal activities: Any activity which is prohibited from the local and international digital usage.

Incident Log: A record of all reported events, including timestamps, actions taken, and resolution status.

Incident Response Plan (IRP): A document defining the roles and responsibilities of the IRT.

Post-Incident Reports: Documentation showing that the institute is actually learned from a past mistake and changed a process.

Approved Supplier List: A register of all vendors categorized by risk level (Low, Medium, High).

Signed Contracts & DPAs: Copies of contracts showing security and Data Processing Addendums (DPA).

Third-Party Audit Reports: Copies of your vendors' ISO 27001 certificates or SOC 2 reports.

Vendor Assessment Logs: Completed security questionnaires from your most recent vendor onboarding.



1 Objectives

The general objective of this policy outlines the standards for the acceptable application of Animal Health Institute's ICT resources. These resources are provided to support business operations and must be used in a manner that protects the institute's reputation and security.

2. Scope

This policy applies to all employees, contractors, and third-party vendors who interact with Animal Health Institute's data, systems, physical premises, networks, hardware, and software resources.

3. Enforcement & Review

This document of ICT policy and producers is designed to be signed by every employee during onboard. It directly derived from ISO 27001:2022 Information Security Management System Controls; where in general failure to comply with this policy might result in discipline violation. These policy shall be reviewed at least annually or when significant changes occur.

4. Policy and Procedures control descriptions.

Table 1 Policy and Procedures controls descriptions

#	Titles	Purposes
1	Asset Management	Manages which ICT assets are accounted for throughout its lifecycle, and protected according to its importance .
2	Access Control Management	It defines who is authorized to access certain information.
3	Information Security Policy	Protects AHI's information resources from all internal, external, deliberate, or accidental threats.
4	Communication Security Policy	Maintain information security during source to destination transmission period.



5	Compliance Security Policy	Identifies and complies applicable legislation, regulations, and contractual requirements.
6	Cryptography & Encryption Policy	Define requirements for the use of cryptographic controls to protect the confidentiality, authenticity, and integrity
7	Human Resource Security	Protects AHI human and digital assets during employment, transitions or terminations period.
8	Business Continuity and Resilience Policy	Sustain applications business continuity during a crisis period and also defines restoration time right after system crash.
9	Policies for Information Security	Define how other policies are created, approved, communicated, and reviewed.
10	Operations Security Policy	Minimize the risk of system failures or unauthorized changes thru correct and secure information management process.
11	Physical and Environmental Security	Prevent unauthorized physical access, damage, and interference to AHI information and facilities.
12	Supplier Relationships Security	Protection of AHI's data as well as assets while accessed, processed, or managed by external suppliers & service providers.



SECTION ONE

4.1 Asset Management

Over View

Asset Management is parts of integrated set of controls under the **Organizational Controls** as well as **Technological Controls**. The goal of this policy is to ensure that the organization knows exactly what hardware, software, and data it owns, where it is, and who is responsible for it.



Name: ICT Asset Management Policy	Owner: ICT Executive	
Policy ID: POL-ASM-01	Version: 2026.1.0	Status: Draft

4.1.1. Purpose

To identify organizational assets and define appropriate protection responsibilities. This policy ensures that all ICT assets are accounted for, managed throughout their lifecycle, and protected according to their importance.

4.1.2. Asset Identification & Inventory

- **The Inventory:** A master **Information Asset Register (IAR)** shall be maintained. Every asset (Hardware, Software, Data, or Service) must be recorded.
- **Minimum Attributes:** For every asset, the register Shall track:
 - Asset Name/ID like Serial Number identification
 - Owner (the person responsible for its protection)
 - Classification (e.g., Public, Internal, Confidential)
 - Physical or Logical Location
 - Application over Sensitive Data

4.1.3. Ownership of Assets

- Every asset shall have a designated **Asset Owner**.
- The Owner is responsible for ensuring the asset is correctly classified, reviewing access rights to that asset periodically, and ensuring proper handling during disposal.

4.1.4. Acceptable Use of Assets

- Employees are permitted to use ICT assets for authorized business purposes only.
- Assets must not be used for illegal activities, unauthorized software installation, or any activity that compromises the company's security posture.



4.1.5. Classification of Information

All information assets especially critical information communication technology infrastructures must be classified based on their legal requirements, value, and sensitivity to unauthorized disclosure or modification:

Table 2 Classification of Information

Classification	Description	Handling Requirement
Confidential	Highly sensitive (PII, Trade Secrets)	Must be encrypted; restricted "Need-to-Know."
Internal	Routine business data	Access limited to employees and contractors.
Public	Marketing, public website	No special restrictions.

4.1.6. Labeling of Information

- Digital information shall be labeled using metadata or headers where possible.
- Physical assets (laptops, servers, hard drives) must be physically tagged/named with a unique **AHI Asset ID** virtually and also physically.

4.1.7. Return and Disposal of Assets

- **Return:** Employees must return all ICT assets (laptops, passwords, keys) immediately upon termination of employment or contract.
- **Secure Disposal:** Storage media (Hard drives, USBs) containing sensitive data must be physically destroyed or cryptographically erased using industry-standard tools before disposal or reuse.



SECTION TWO

4.2. Access Control Policy

Over View

Access Control is one of the most scrutinized areas during an audit. Under the 2022 update, this primarily aligns with Clause 8.2 (Operational Planning) and specific physical control. Below is a concise, policy focused specifically on Access Control.

Name: ICT Access Control Policy	Owner: ICT Executive	
Policy ID: POL-ACC-01	Version: 2026.1.0	Status: Draft



4.2.1. Purpose

To ensure that access to Animal Health Institute's information systems is restricted to authorized users and that such access is granted only to the extent necessary for their job functions.

4.2.2. General Principles

- **Need-to-Know:** Access is restricted to the information required to perform a specific task.
- **Least Privilege:** Users are granted the minimum level of permissions required (e.g., "Read-only" instead of "Read/Write").
- **Segregation of Duties:** Conflicting duties shall be split between different people to reduce the risk of fraud or error (e.g., the person requesting access cannot be the same person approving it).

4.2.3. User Access Management

- **Provisioning:** Access is granted only via a formal "Access Request Form" approved by the relevant Section Head.
- **De-provisioning:** Upon termination of employment, all access must be revoked **immediately** (within 12Hours of termination).
- **Access Review:** Privileged access (Admin) must be reviewed **quarterly**, and standard user access **annually**, to ensure permissions are still appropriate.

4.2.4. Authentication Requirements

- **Multi-Factor Authentication (MFA):** MFA shall be implemented for all remote access (VPN) and privileged accounts.
- **Password Complexity:** Passwords must be a minimum of 6 characters, including uppercase, lowercase, numbers, and symbols.
- **Unique Identity:** Generic or shared accounts (e.g., "admin@ahi.com" or "guest") are strictly prohibited. Every action shall be attributable to a specific individual.



4.2.5. Privileged Access Management

- Privileged accounts (Domain Admin, Root, etc.) shall be used only for administrative tasks and not for routine activities like email or web browsing.
- A separate account must be used for administrative duties.

4.2.6. Remote Access & Mobile Devices

- Remote access is permitted; never the less; if VPN is provided by AHI or other approved partners, then the connection shall be through that specified encrypted tunnels.
- Unattended devices must be configured with an automatic screen lock after **5 minutes** of inactivity.

4.2.7. Monitoring & Logging

- All successful and failed login attempts to critical systems shall be documented in a log.
- Logs must be protected against unauthorized modification and kept quarantine



SECTION THREE

4.3. Information Security Policy

Overview

Information Security Policy is the foundation of Animal Health Institute's ISMS, it starts with a high-quality pattern for the **Information Security Policy** which is designed to be concise and hitting parts of ISO 27001.



Name: Information Security Policy	Owner: ICT Executive	
Policy ID: POL-IS-01	Version: 2026.1.0	Status: Draft

4.3.1. Purpose

The purpose of this policy is to protect Animal Health Institute's information assets from all internal, external, deliberate, or accidental threats. Information security is critical to AHI's business operations, legal compliance, and brand reputation.

4.3.2. Objectives

Information security policies and procedure objectives are to ensure:

- **Confidentiality:** Information is accessible only to those authorized to have access.
- **Integrity:** Information is accurate and complete, and protected from unauthorized modification.
- **Availability:** Information and vital services are available to users when needed.

4.3.4. Management Responsibilities

Management is committed to the Information Security Management System (ISMS) and ensures:

- Security objectives are established and aligned with the business strategy.
- Resources are available for the ISMS to function effectively.
- Continual improvement is promoted through regular reviews.

4.3.5. Key Security Principles

- **Risk-Based Approach:** the institute shall conduct regular risk assessments to identify and treat threats.
- **Compliance:** Animal Health Institute inherited ISO27001:2022 international ISMS framework; furthermore, this document shall comply with all national as well as international applicable legal, regulatory, and contractual requirements.



Animal Health Institute ICT Policy and procedures

ICT Executives
Page 11 of 52

- **Awareness:** Animal Health Institute's staff shall undergo security awareness training annually.
- **Incident Reporting:** Any actual or suspected security breaches shall be reported immediately to the institutes higher official via Internal Reporting Channel and activate IDPS.



SECTION FOUR

4.4. Communication Security Policy

Overview

In the ISO/IEC 27001:2022 framework, **Communications Security** is primarily addressed to ensure; information is protected as it travels across networks, whether internal, public, or wireless. Likewise, the information is safe while it is organized, processed and transfer internally/externally.



Name: ICT Communication Security Policy	Owner: ICT Executive	
Policy ID: POL-COM-01	Version: 2026.1.0	Status: Draft

4.4.1. Purpose

The purpose of this policy is to maintain the security of information within networks and to protect the supporting infrastructure from unauthorized access or compromise during transmission.

4.4.2. Network Controls

- **Segregation:** The corporate network must be segregated into functional zones like; Guest Wi-Fi, DMZ, support staff as well as technical staff using VLANs). High-sensitivity data must reside in restricted segments.
- **Firewalls:** Managed firewalls must be deployed at all perimeters. "Deny All" must be the default rule; only explicitly required traffic is permitted.
- **Intrusion Prevention:** Automated systems (IDS/IPS) shall be used to monitor network traffic for malicious patterns.

4.4.3. Security of Network Services

- **Encryption in Transit:** All sensitive data transmitted over public networks shall be encrypted and transfer using strong protocols (e.g., TLS 1.2 or higher, IPsec VPN).
- **Wireless Security:** Access to corporate Wi-Fi shall require WPA3 or WPA2-Enterprise (802.1X) authentication. Pre-shared keys (PSKs) are prohibited for employee access.
- **Public Networks:** Employees are prohibited from accessing company systems via unencrypted "Open" public Wi-Fi without using a company-approved VPN.

4.4.4. Information Transfer

- **Email Security:** Confidential data shall not be sent via unencrypted email. Use secure file-sharing platforms or encrypted attachments.



- **Messaging:** Instant public messaging (Slack, Teams) should be used for internal communication while Sensitive technical credentials or PII should never be pasted into chat history without authorization.
- **Transfer Agreements:** Before sharing data with third parties, a **Non-Disclosure Agreement (NDA)** or a **Data Processing Agreement (DPA)** shall be introduced.

4.4.5. Web Filtering & Electronic Messaging

- **Content Filtering:** Animal Health Institute shall block access to high-risk website categories (e.g., gambling, malware-hosting sites, and unauthorized file-sharing).
- **Anti-Phishing:** All incoming email must pass through a security gateway to scan for malicious links, attachments, and spoofed headers.

4.4.6. Social Media & work time and device

- Social media and other content created materials shall be treated according to social moral structure.

4.4.7. Network Redundancy

- To ensure the **Availability** of communications, critical network paths should have redundant hardware or failover internet circuits (e.g., primary fiber with a 5G/satellite backup).



SECTION FIVE

4.5. Compliance Security Policy

Over View

Compliance is no longer just about following laws; it is about ensuring the ISMS meets legal, regulatory, and contractual obligations, as well as the requirements of the standard itself. This aligns primarily with different sections of the framework.



Name: ICT Compliance Security & Legal Policy	Owner: ICT Executive & Legal Counsel	
Policy ID: POL-CMP-01	Version: 2026.1.0	Status: Draft

4.5.1. Purpose

To ensure that Animal Health Institute identifies and complies with all applicable legislation, regulations, and contractual requirements related to information security, and to avoid breaches of any legal obligations.

4.5.2. Identification of Legislation

- **Legal Register:** Animal Health Institute shall maintain a "Legal & Regulatory Register" listing all laws applicable to its ICT operations (e.g., INSA, GDPR, CCPA, HIPAA, and local Cybercrime Acts).
- **Updates:** This register must be reviewed periodically or whenever there is necessary due to a significant change in the business jurisdiction.

4.5.3. Intellectual Property Rights (IPR)

- **Software Licensing:** Only legally acquired software may be installed on the institute's assets. Unauthorized copying or use of "cracked" software is not recommended.
- **Proof of Ownership:** The ICT department must maintain records of licenses and original media for all software assets and better applicable configurations.
- **Copyright:** Employees shall respect the copyright of third-party materials (code, images, documents) found on the digital and physical landscape.

4.5.4. Protection of Records

- **Retention Schedule:** Records (logs, financial data, employee files) shall be protected from loss, destruction, and falsification in accordance with legal and business requirements.
- **Storage:** Sensitive records shall be stored in secured way and periodically pass thru a "back-up" procedures according to the **section one-Asset Management Policy**.



4.5.5. Privacy and Protection of PII

- **Data Protection:** The organization shall implement a Data Protection Policy to ensure the privacy of Personally Identifiable Information (PII) as required by relevant laws (e.g., GDPR).
- **Privacy by Design:** All new ICT systems shall undergo a **Data Protection Impact Assessment (DPIA)** before implementation.

4.5.6. Regulation of Cryptographic Controls

- Animal Health Institute shall comply with national and international laws regarding the import, export, and use of cryptographic technology.

4.5.7. Independent Review of Information Security

- **Internal Audit:** An internal audit of the ICT environment shall be conducted at planned intervals to ensure the organization is following its own policies.
- **Technical Compliance:** Managers must regularly review the technical compliance of systems within their area of responsibility (e.g., verifying that critical infrastructures are indeed secure).



SECTION SIX

4.6. Cryptography & Encryption Policy

Over View

Cryptography is a vital technical control. It has been updated and consolidated under the **Use of Cryptography**. This policy ensures that the institute's data remains unreadable to unauthorized parties, while it is in storage and/or when it is moving across the LAN/WAN.



Name: ICT Cryptography & Encryption Policy	Owner: ICT Executive	
Policy ID: POL-CRY-01	Version: 2026.1.0	Status: Draft

4.6.1. Purpose

To define the requirements for the use of cryptographic controls to protect the confidentiality, authenticity, and integrity of Animal Health Institute's information assets.

4.6.2. General Principles

- **Risk-Based Application:** Encryption shall be applied based on the classification of the data (e.g., for "Confidential" data, encryption is recommended).
- **Standard Algorithms:** Only industry-standard, non-deprecated cryptographic algorithms shall be used. Proprietary or "home-grown" encryption is strictly prohibited.
- **Algorithm Strength:**
 - **Symmetric Encryption:** AES-256 is the minimum standard for data at rest.
 - **Asymmetric Encryption:** RSA (3072-bit or higher) or Elliptic Curve Cryptography (ECC) shall be used for digital signatures and key exchanges.
 - **Hashing:** SHA-256 or higher must be used for integrity checks; MD5 and SHA-1 are prohibited.

4.6.3. Data at Rest

- **Endpoints:** Staffs laptops, desktop computers as well as mobile devices shall use Disk Encryption (e.g., BitLocker, FileVault).
- **Backups:** All backup media, whether physical tapes or cloud-based snapshots, shall be encrypted before storage.
- **Databases:** Sensitive fields (e.g., PII, passwords) shall be hashed or encrypted within the database layer.



4.6.4. Data in Transit

- **Web Traffic:** All internal and external web services shall be delivered over HTTPS using TLS 1.2 or higher. TLS 1.0 and 1.1 shall be disabled.
- **Remote Access:** All VPN connections shall utilize strong encryption protocols (e.g., OpenVPN, IPsec, or WireGuard).
- **Email:** Use of S/MIME or encrypted file-transfer portals is required when sending "Confidential" information externally.

4.6.5. Key Management

The security of encryption is only as strong as the security of the keys.

- **Generation:** Keys shall be generated using hardware security modules (HSM) or secure cloud Key Management Services (KMS) like AWS KMS.
- **Storage:** Private keys and master keys shall not store in plain text or in the same location as the encrypted data.
- **Rotation:** Cryptographic keys shall be rotated at least annually or immediately if a compromise is suspected.
- **Recovery:** A secure process for key escrow or recovery shall exist to prevent permanent data loss due to a lost key.

4.6.6. Digital Signatures

- Digital signatures shall be used for high-value transactions or legal documents to ensure non-repudiation and data integrity.



SECTION SEVEN

4.7. Human Resource Security

Overview

Human Resource Security according to ISO/IEC 27001:2022 framework, ensures that employees and contractors understand their responsibilities and are suitable for their roles. This aligns with **People Controls** and is broken down into three phases: before, during, and after employment.



Name: ICT Human Resource Security Policy	Owner: ICT Executive & HR Executives	
Policy ID: POL-HRS-01	Version: 2026.1.0	Status: Draft

4.7.1. Purpose

To ensure that all employees and contractors are briefed on their information security obligations, are capable of performing their duties securely, and protects information as well as digital assets during employment, transitions or terminations period.

4.7.2. Prior to Employment

- **Screening:** Background checks shall be conducted for all candidates proportional to the business requirements and the classification of data they will access. This includes identity verification and, where permitted by law, criminal and credit checks.
- **Terms and Conditions:** Employment contracts shall include a signed **Non-Disclosure Agreement (NDA)** and clearly state the individual's responsibility for information security.

4.7.3. During Employment

- **Management Responsibilities:** Managers shall confirm that all team members are aware of the security requirements relevant to their specific roles.
- **Information Security Awareness:** All personnel shall receive regular security awareness training (e.g., phishing, password hygiene, data handling). It must be completed upon hiring (Onboarding), annually thereafter or whenever there are significant changes to security policies.
- **Disciplinary Process:** A formal disciplinary process shall be maintained for employees who commit information security breaches.

4.7.4. Termination or Change of Employment

- **Responsibilities:** Security responsibilities that remain valid after termination (such as those in the NDA) shall be communicated to the individual during an exit process.



- **Asset Return:** A formal process must be followed to ensure all physical and logical assets (laptops, badges, tokens, and software licenses) are returned.
- **Access Revocation:** Information access rights must be removed or adjusted **on or before** the final day of employment.

4.7.5. Remote Working & Bring Your Own Device (BYOD)

- **Remote Security:** contractors, regional laboratory staffs, working from a distance must follow the same security protocols as office-based staff, including the use of encrypted tunnels and secure physical storage for the institute's equipment.
- **Device Approval:** No personal devices may be used for institutes business unless they meet the technical standards defined in the **ICT Asset Management Policy**.



SECTION EIGHT

4.8. Business Continuity & Resilience Policy

Overview

Business Continuity has been updated and simplified under these Information Security during Disruption and ICT Readiness for Business Continuity sections. The focus here is not just "getting the business back to work," but ensuring that security controls remain active even during a disaster.

Name: ICT Business Continuity & Resilience Policy	Owner: ICT Executive and Quality Manager	
Policy ID: POL- BCP -01	Version: 2026.1.0	Status: Draft



4.8.1. Purpose

The purpose of this policy is to ensure system's business continuity during a crisis time and also assures it's resilient which has to be restored within agreed-upon timeframes following a disruption.

4.8.2. Planning for Information Security Continuity

- **Risk Assessment:** The institute shall identify potential disruptions (e.g., cyberattacks, power outages, natural disasters, intrusion) and determine the security requirements needed during these events.
- **Redundancy of Controls:** Security measures (such as firewalls and access logs) must remain operational during a failover to backup systems. A disaster must not be used as an excuse to bypass security protocols.

4.8.3. ICT Readiness

To ensure technical resilience, the ICT department shall define and meet the following recovery objectives:

- **System Testing and Training:** testing and training shall not be conducted on production server. A separate training and/or development area should be prepared in order to secure production site.
- **Recovery Time Objective (RTO):** The maximum allowable time that an ICT service can be down

Table 3 Recovery Time Schedules

No.	Description	RTO
1	SILABFA small crash	1hr – 5 hr
2	SILABFA serious crash	72hr – 96hr
3	Website and email	1hr
4	AHI Internal Communication	Less than 30min
5	Internal Network Fail	Less than 30min



- **Recovery Point Objective (RPO):** The maximum tolerable data loss measured in time must be not more than 78 hours old.

4.8.4. Backup and Redundancy

- **Backup Frequency:** Critical data including SILABFA as well as Bio informatics server must be backed up at least daily.
- **Off-site Storage:** Backups must be stored in a physically separate location (or separate cloud region) from the primary data to prevent concurrent loss.
- **Testing:** Backup restoration must be tested **quarterly** to ensure data integrity.

4.8.5. Response and Recovery Procedures

- **Disaster Recovery Plan (DRP):** A documented DRP must exist for all critical ICT services, detailing the step-by-step technical restoration process.
- **Communication:** A "Crisis Communication Plan" must be maintained with emergency contact details for all key ICT personnel, Quality manager, data manager including third-party vendors (e.g., IZS Teramo).

4.8.6. Testing and Review

- **Annual Testing:** ICT business continuity plans shall be tested at least annually (e.g., via tabletop exercises or full failover simulations).
- **Post-Incident Review:** Following any significant disruption or test, a "Lessons Learned" report must be generated to improve the plan.



SECTION NINE

4.9. Policies for Information Security

Overview

"Policy for Information Security Policies" is essentially the **meta-policy** purpose is to define how all other policies are created, approved, communicated, and reviewed to ensure this policy statement isn't just "shelf-ware" rather it is active, living documents.

Name: Policy for Information Security Policies	Owner: ICT Executive and Governance Committee	
Policy ID: POL- GOV-01	Version: 2026.1.0	Status: Draft



4.10.1. Purpose

To provide a framework for the development, approval, and maintenance of all Information Security Management System (ISMS) policies, ensuring they remain aligned with business goals and regulatory requirements.

4.10.2. Policy Hierarchy

The ISMS documentation shall follow a three-tier structure:

- **Tier 1: High-Level ISMS Policy:** The core statement of intent approved by the Board.
- **Tier 2: Topic-Specific Policies:** Detailed rules for specific areas including Access Control, Cryptography, Assets on the form of procedures.
- **Tier 3: Procedures & Standards:** Step-by-step instructions and technical configurations including Firewall Rule Standard, Password Change Procedure on the form of practices.

4.10.3. Creation and Format

All policies must follow the standard corporate template and include:

- **Unique Identifier:** (e.g., POL-XXX-00).
- **Version Control:** Major versions for board-approved changes; minor versions for formatting edits. The version (**Version:** 2026.1.0) contains first published year, Major updates and Minor updates.
- **Owner:** A designated individual responsible for the content.

4.10.4. Review and Approval

- **Annual Review:** All policies must be reviewed at least **once every 12 months** to ensure they remain relevant to the current threat landscape.
- **Triggered Review:** Policies must be reviewed immediately following a major security incident or a significant change to the ICT infrastructure.



- **Approval Authority:** Topic-specific policies are approved by the chief of executive while high-level Information Security Policy must be signed by the director or deputy director of the institute.

4.10.5. Communication

- **Accessibility:** All policies must be accessible to all relevant employees and contractors via the Internal SharePoint and Library.
- **Acknowledgment:** Employees must acknowledge (electronically or via signature) that they have read and understood the policies during onboarding and after major revisions.
- **Summaries:** For complex technical policies, a "Key Points" summary shall be provided to non-technical staff.

4.10.6. Exceptions

- **Formal Request:** Any deviation from a policy (e.g., a business requirement that prevents the use of MFA on a legacy system) must be documented as an **Exception Request**.
- **Risk Acceptance:** Exceptions must be time-bound and approved by the ICT Executive, with the associated risk formally accepted in the Risk Register.



SECTION TEN

4.10. Operations Security Policy

Overview

In the ISO/IEC 27001:2022 framework, **Operations Security** is the "engine room" of the ISMS. It ensures that AHI’s IT systems run securely and predictably on a day-to-day basis. This aligns with how systems are managed, documented, and protected from technical failures.

Name: ICT Operations Security Policy	Owner: ICT Executive	
Policy ID: POL-OPS-01	Version: 2026.1.0	Status: Draft



4.10.1. Purpose

To ensure the correct and secure operation of information processing facilities and to minimize the risk of system failures or unauthorized changes.

4.10.2. Operating Procedures

- **Documentation:** Standard Operating Procedures (SOPs) must be documented for all routine ICT tasks. These are backups, maintenance (basic PC configuration), IDPS, NOC/SOC, Remote security, Incidence LOG and others.
- **Accessibility:** These procedures must be treated as "Internal" documents and made available to all authorized IT staff.

4.10.3. Change Management

To prevent security gaps during system updates:

- **Formal Requests:** All changes to the production environment must be logged via a Change Request (CR).
- **Testing:** Changes must be tested in a non-production (sandbox) environment before deployment.
- **Back-out Plan:** Every change shall have a documented "Rollback" plan in case the implementation fails.
- **Approval:** High-impact changes require approval from the higher officials or the ICT Executive.

4.10.4. Capacity Management

- **Monitoring:** The ICT team shall monitor the use of resources (CPU, disk space, memory, network bandwidth).
- **Planning:** Future capacity requirements shall be projected to ensure system availability and prevent outages caused by resource exhaustion.



4.10.5. Malware Protection

- **Detection:** All endpoints and servers shall have centrally managed anti-malware/EDR (Endpoint Detection & Response) tools installed.
- **Updates:** Signature and engine updates must be automated.
- **User Restriction:** Employees are prohibited from disabling security software or installing unauthorized applications ("Shadow IT").

4.10.6. Logging and Monitoring

- **Audit Logs:** Logs for user activities, exceptions, and security events must be produced and kept for at least 90 days.
- **Protection:** Logs must be protected against unauthorized tampering or deletion.
- **Administrator Logs:** Privileged user actions (admin logins, password changes) must be reviewed regularly.

4.10.7. Technical Vulnerability Management

- **Scanning:** Regular vulnerability scans must be conducted on the network and applications.
- **Patching:** Security patches shall be applied based on risk:
 - **Critical:** Within 7 days.
 - **High/Medium:** Within 30 days.
- **Legacy Systems:** Systems that can no longer be patched shall be isolated in a restricted network segment or decommissioned.

4.10.8. Information Security Roles & Responsibilities

- **ICT Executive:** Responsible for the overall design and management of the ISMS.
- **Asset Owners:** Responsible for the protection of specific data sets or hardware (as defined in the Asset Management Policy).
- **The IT Team:** Responsible for the technical implementation of security controls.
- **All Personnel:** Responsible for following security policies and reporting incidents.

4.10.9. Segregation of Duties

To reduce the risk of fraud or accidental error:



- No single person shall have the power to initiate, approve, and execute a high-risk transaction or system change.

4.10.10. Information Security in Project Management

- Information security must be addressed in every project, regardless of its size or nature.
- A **Security Impact Assessment** must be conducted at the start of any project (e.g., migrating to a new cloud provider or developing a new app/system) to ensure security "by design."



SECTION ELEVEN

4.11. Physical and Environmental Security

Overview

Physical and Environmental Security focuses on preventing unauthorized physical access, damage, or interference to Animal Health Institute's ICT infrastructure premises and information. This section of security aligns with physical Controls. Besides to the cloud or servers and other critical ICT infrastructures; end-user devices have physical assets like laptops and other electronic devices which must be secured.

Name: Physical and Environmental Security Policy	Owner: ICT Executive and General Service	
Policy ID: POL-PHY-01	Version: 2026.1.0	Status: Draft



4.11.1. Purpose

To prevent unauthorized physical access, damage, and interference to Animal Health Institutes information and information processing facilities.

4.11.2. Physical Security Perimeters

- **Defined Boundaries:** Security perimeters (walls, card-controlled gates, or locked doors) shall be used to protect areas that contain sensitive information or ICT infrastructure.
- **Unattended Areas:** All doors to secure areas shall be kept locked and periodically checked.

4.11.3. Physical Entry Controls

- **Access Logs:** Visitors shall sign in/out and escorted by an authorized employee at all times.
- **Badges:** Employees shall wear/carry their identification badges while on premises.
- **Unauthorized Access:** Employees are prohibited from "tailgating" (letting someone into the building behind them without a badge swipe).

4.11.3. Securing Offices, Rooms, and Facilities

- **Server Rooms:** Access to server rooms or network closets is restricted to authorized IT personnel only.
- **Clear Desk Policy:** Confidential paperwork and removable media shall be locked away when workstations are unattended.
- **Clear Screen Policy:** Computer screens shall be locked d when a user leaves their desk.

4.11.5. Physical Security Monitoring

- **Surveillance:** Secure areas (entries, exits, and server rooms) shall be monitored by CCTV or alarm systems.
- **Review:** Security logs and camera footage must be reviewed following any suspected physical breach.

4.11.6. Protecting Against Physical and Environmental Threats

- **Environmental Controls:** Data centers and server rooms shall be equipped with climate control (AC), fire detection, and suppression systems.



- **Threat Protection:** Critical ICT equipment should be protected from fire, flood, earthquake, and other forms of natural or man-made disasters.

4.11.7. Working in Secure Areas

- **Photography:** Unauthorized photography or video recording in secure areas (like the server room) is strictly prohibited.
- **External Support:** Third-party maintenance personnel must be supervised while working in secure zones.

4.11.8. Equipment Siting and Protection

- **Placement:** Equipment (servers, printers, etc.) should be placed to reduce the risk of environmental threats and unauthorized viewing.
- **Power Supply:** Critical equipment must be protected from power failures using UPS (Uninterruptible Power Supply) or backup generators.
- **Cabling Security:** Power and telecommunications cables must be protected from interception or damage.

4.11.9. Secure Disposal or Reuse of Equipment

- **Media Sanitization:** Before any hardware is disposed of or sent for repair, all sensitive data shall be destroyed using software wiping or physical destruction (shredding).



SECTION TWELVE

4.12. Supplier Relationships Security

Overview

Supplier Relationships are addressed under different controls fragments where it is crucial because an organization's security is only as strong as its weakest vendor (e.g., cloud providers, IT consultants, or maintenance staff).

Name: Supplier Relationships Policy	Owner: ICT Executive and Procurement Manager	
Policy ID: POL- SUP-01	Version: 2026.1.0	Status: Draft



4.12.1. Purpose

The purpose of these security is to ensure that Animal Health Institute's information assets are protected when accessed, processed, or managed by external suppliers and service providers.

4.12.2. Information Security in Supplier Relationships

- **Risk Assessment:** Before engaging any new supplier who will handle sensitive data or access AHI's network, a **Third-Party Risk Assessment** must be conducted.
- **Standard Requirements:** All suppliers must adhere to AHI's minimum security requirements, including MFA, encryption at rest, and timely patching.

4.12.3. Addressing Security within Supplier Agreements

- **Contractual Clauses:** Security requirements must be formally documented in contracts or Service Level Agreements (SLAs). Key clauses must include:
 - Right to Audit.
 - Incident Notification (e.g., must notify us within 24 hours of a breach).
 - Data Return/Deletion upon contract termination.
- **NDA:** A Non-Disclosure Agreement (NDA) must be signed before any confidential information is shared during the bidding or onboarding process.

4.12.4. Managing Information Security in the ICT Supply Chain

- **Cloud Services:** For cloud providers (SaaS/PaaS/IaaS), the organization shall review the provider's **SOC 2 Type II** or **ISO 27001 certification** reports annually to ensure they meet our security standards.
- **Upstream Suppliers:** Critical suppliers must provide transparency regarding their own sub-contractors who may have access to our data.

4.12.5. Monitoring and Review of Supplier Services

- **Annual Review:** High-risk suppliers shall be reviewed annually. This may involve a self-assessment questionnaire or a formal audit of their security controls.



- **Performance Tracking:** Any security incidents caused by a supplier must be logged and used to evaluate the continuation of the partnership.

4.12.6. Managing Changes to Supplier Services

- Any major changes to a supplier's service (e.g., moving data to a new geographic region or changing core software) must be assessed for security impact before the change is accepted.

SECTION THIRTEEN



4.13. System acquisition, development, & maintenance Security

Overview

This domain ensures that security is not an afterthought but is baked into the entire lifecycle of a system—from the moment our institutes buy or build it, through its daily use, until it is retired.

Name: System Acquisition, Development, and Maintenance Policy	Owner: ICT Executive and Quality Manager	
Policy ID: POL- SDLC -01	Version: 2026.1.0	Status: Draft



4.13.1. Purpose

To ensure that information security is an integral part of information systems across their entire lifecycle. This includes systems developed in-house and those acquired from third parties.

4.13.2. Secure Requirements & Acquisition

- **Security Specifications:** Before acquiring or starting the development of any new system, security requirements (e.g., encryption, logging, MFA) shall be defined and documented.
- **Vendor Assessment:** Commercial Off-The-Shelf (COTS) software shall be evaluated for security vulnerabilities and "Privacy by Design" features before purchase.

4.13.3. Secure Development Lifecycle

For internal development projects, the following rules apply:

- **Separation of Environments:** Development, Testing, and Production environments must be strictly segregated. No developer shall have "write" access to production code without a formal deployment process.
- **Secure Coding:** Developers shall pass thru industry-standard secure coding practices (e.g., **OWASP**) to prevent common vulnerabilities like SQL Injection and Cross-Site Scripting (XSS).
- **Code Review:** All code changes must be peer-reviewed for both functionality and security before being merged.

4.13.4 Protection of Test Data

- **No Production Data:** Real customer data or PII must **never** be used in development or testing environments.
- **Masking/Anonymization:** If production data is required for testing, it must be scrambled, masked, or anonymized so that individuals cannot be identified.

4.13.5. System Acceptance Testing

- **Security Testing:** New systems or major updates shall undergo security testing (e.g., vulnerability scanning or penetration testing) before being promoted to production.



- **User Acceptance:** The Asset Owner must formally sign off on the system's security and functionality before "Go-Live."

4.13.6. Secure System Engineering

- **Secure Architecture:** Systems must be designed with "Defense in Depth" in mind.
- **Hardening:** Default passwords, unnecessary services, and insecure protocols must be removed or disabled before a system is deployed (System Hardening).

4.13.7. Maintenance and Change Management

- **Patching:** Systems shall be maintained with the latest security updates as per the **ICT Operations Security Policy**.
- **Integrity:** Any maintenance task that requires privileged access must be logged, and any changes to system files must be monitored for unauthorized modifications by the Information security experts.



Animal Health Institute ICT Policy and procedures

ICT Executives
Page I of I

APPENDIX I: User Acknowledgment

I have read, understood, and agree to abide by the AHI's ICT Policy rules and regulations.

Name: _____

Signature: _____

Date: _____